

Glamsterdam Solidity Readiness Triage Toolkit

Proposal for the Ethereum Foundation ESP Glamsterdam Grants Round.

Project Overview

Glamsterdam Solidity Readiness Triage Toolkit extends AISolidityAuditor, an open-source Solidity security triage assistant. The project provides a GitHub Action and reporting workflow that helps Solidity maintainers identify source patterns that may need manual review as Glamsterdam candidates evolve.

The toolkit focuses on review prompts around gas-sensitive loops, low-level EVM usage, native ETH transfer assumptions, block context dependencies, and contract-size watch points. It does not provide a formal audit or a protocol compatibility guarantee. Every result is labeled as requiring manual review.

ESP Wishlist Alignment

This proposal targets the ESP Wishlist item Glamsterdam Grants Round. The round asks for work that helps the Ethereum community prepare for and adapt to Glamsterdam, including developer tooling updates, impact analysis tooling, monitoring tooling, and data-driven research.

This project fits as open-source developer tooling and impact-analysis support for Solidity maintainers. It turns upgrade-readiness checks into reproducible CI artifacts: Markdown reports, JSON outputs, SARIF results, GitHub Action artifacts, and optional PR comments.

Problem

Protocol upgrades can affect assumptions embedded in contracts and developer workflows. For Glamsterdam, candidate changes such as gas repricing, new EVM capabilities, native ETH transfer logs, ePBS, Block-Level Access Lists, and contract-size discussions may require maintainers to review code patterns that are not traditional vulnerabilities.

Small Solidity teams often do not have a repeatable upgrade-readiness checklist or CI artifact for this type of review. Raw static analysis is valuable, but it does not package upgrade-readiness prompts into reviewer-friendly outputs with clear evidence boundaries.

Current Base

AISolidityAuditor already provides:

- Slither integration with raw Slither JSON preservation.
- Slither-only audit-report.md and findings.json outputs.
- A reusable GitHub Action with mode: glamsterdam-readiness.
- Separate glamsterdam-readiness-report.md and glamsterdam-findings.json artifacts.
- Combined SARIF with distinct tool/source metadata for Slither and readiness heuristics.
- Path-filtered readiness scanning for real Solidity repositories.
- 30 Solidity evaluation fixtures.
- Assistive AI explanations that always require manual review.
- Docker-based verification commands and sandbox documentation.

Baseline public demos have already been completed for solmate and OpenZeppelin Contracts at pinned commits. The demo artifacts document setup assumptions, Slither output, readiness output, SARIF tags, and limitations. Grant funding is requested to validate, harden, measure, and release this MVP for broader ecosystem use, not to build the initial mode from scratch.

Proposed Scope: 6-8 Weeks

1. Harden and validate Glamsterdam readiness mode

- Lock evidence boundaries between Slither findings and readiness heuristics in Markdown, JSON, and SARIF.
- Maintain end-to-end Action workflow validation for readiness artifacts, SARIF upload, artifacts, and PR comments.
- Document mode usage, path filtering, limitations, and reviewer-facing evidence boundaries.

2. Real-project validation and artifact publication

- Preserve the completed solmate and OpenZeppelin Contracts baseline demos as public evidence.
- Refresh demo artifacts when rule tuning changes output materially.
- Add an optional third demo, likely Uniswap v4-core, if CI runtime and setup complexity are reasonable.
- Publish a concise validation note for each demo with commit SHA, setup assumptions, Slither status, readiness scope, SARIF tag coverage, and known limitations.

3. Improve heuristic precision and false-positive handling

- Execute the published false-positive measurement protocol using sampled two-reviewer classification per detector.
- Publish per-detector precision notes in the benchmark report.
- Tune high-recall rules where the measurement shows excessive noise.
- Keep rule metadata explicit: confidence, rationale, related fork candidates, inline suppression, and baseline suppression.

4. Publish benchmark notes and documentation

- Update the benchmark report with raw Slither vs AISolidityAuditor comparison notes.
- Document AI as assistive only, with no model-driven removal of manual review.
- Record Foundry, Hardhat, remapping, and CI setup limitations transparently.

5. Prepare tagged Action release

- Publish a tagged AISolidityAuditor-action@v1 release or equivalent stable Action tag.
- Finalize release notes, usage docs, maintenance expectations, and a public completion report.

Budget Request

Requested budget: USD 12,000 equivalent.

Suggested allocation:

- Hardening, validation, and evidence-boundary work: 25%
- Heuristic precision and fixture/benchmark coverage: 25%
- Real-project validation and artifact publication: 25%
- Tagged Action release and documentation: 15%
- Maintenance buffer: 10%

Deliverables

- Open-source GitHub Action with mode: glamsterdam-readiness.
- Path-filtered readiness scans via readiness_path.
- Separate Slither and Glamsterdam readiness artifacts.
- Combined SARIF with distinct source/tool metadata.
- At least two documented public repository validation runs.
- Published false-positive measurement notes by detector.
- Updated benchmark report and demo guide.
- Tagged Action release or stable Action tag.
- Public final report with links to code, artifacts, SARIF results, and known limitations.

Success Metrics

- audit-report.md and findings.json contain Slither evidence only.
- glamsterdam-readiness-report.md and glamsterdam-findings.json contain readiness heuristics only.
- SARIF merges both sources with distinct tool/source metadata and Glamsterdam tags on readiness rules only.
- 30 existing Solidity evaluation fixtures continue to pass.
- At least two public Solidity repositories have documented readiness validation runs.
- Per-detector readiness false-positive rates are measured and published.
- A stable tagged GitHub Action release is published.
- A public completion report documents deliverables, benchmark findings, demo runs, and limitations.

Risks and Mitigations

- Glamsterdam EIPs may change: findings are conservative readiness prompts, and documentation avoids compatibility guarantees.
- False confidence: Slither findings stay separate from readiness heuristics, and every result requires manual review.
- Over-broad heuristics: rules are documented as review triggers, not vulnerability claims; precision is measured separately and high-noise rules can be tuned.
- Complex project compatibility: demo notes record setup assumptions and limitations instead of hiding failures.

Links

- Repository: <https://github.com/PXLabs-code/AISolidityAuditor>
- Real-project demo guide:
<https://github.com/PXLabs-code/AISolidityAuditor/blob/master/docs/real-project-demo.md>
- Benchmark report:
<https://github.com/PXLabs-code/AISolidityAuditor/blob/master/docs/benchmark-report.md>
- Glamsterdam Wishlist item:
<https://esp.ethereum.foundation/applicants/wishlist/glamsterdam-round>